

Chapter 9

Explain the purpose of mitigation techniques used to secure the enterprise

Segmentation

- Segmentation is used within an enterprise's network infrastructure.
- Its purpose is to compartmentalize the network, creating isolated segments that restrict the lateral movement of potential attackers.
- By doing so, segmentation limits the impact of a breach, preventing cyber intruders from traversing freely across the network.
- It ensures that even if one layer is breached, the intruder is contained within a confined area, unable to access critical assets or move deeper into the network.

The following list defines each of the major types of segmentation:

- **Physical segmentation:** This method separates a network into smaller segments using routers, switches, and firewalls. It's like building different rooms within a fortress, each with a unique access control. Physical segmentation is ideal for large organizations with diverse network requirements, allowing for the isolation of sensitive data and critical systems.
- **Virtual Local Area Networks (VLANs):** VLANs create logical network segments within a single switch. VLANs are commonly used to group devices based on function or department, reducing broadcast traffic and enhancing network efficiency.
- **Subnetting:** Subnetting divides an IP network into smaller subnetworks, each with a subnet mask. Subnet segmentation simplifies network management and security by grouping devices with similar purposes or security requirements. This ensures efficient use of IP addresses and improves network performance.
- **Micro-segmentation:** Micro-segmentation takes segmentation to a granular level, applying security policies to individual workloads or devices. Micro-segmentation is crucial in cloud environments and data centers, where it provides fine-grained control over traffic flows, preventing lateral movement by cyber threats. It's like having individual vaults for each piece of treasure.

Let's look at some of the reasons for using segmentation:

- **Enhanced security:** Segmentation makes it harder for attackers to access sensitive data or critical systems. If our network had a malware attack, then using segmentation would limit the number of computers affected.
- **Access control:** By segmenting networks, organizations can implement access controls more effectively. This ensures that only authorized users or devices can access specific resources, reducing the attack surface.
- **Compliance requirements:** Many industries have regulations and compliance standards, such as the Payment Card Industry Data Security Standard (PCI DSS), which relates to credit card payments in a secure environment. Another important regulation is the Health Insurance Portability and Accountability Act (HIPAA), which relates to the confidentiality, integrity, and availability of Protected Health Information (PHI). This protects individuals' rights to their health information and facilitates the secure exchange of healthcare data. We need to segment the systems holding this data to ensure compliance.
- **Performance optimization:** Segmentation can lead to improved network performance by reducing broadcast domains and congestion. It ensures that network resources are used efficiently, enhancing the overall user experience.
- **Isolation of critical systems:** Organizations often have critical systems that need an extra layer of protection. Segmentation isolates these systems, safeguarding them from potential threats.
- **Scalability and agility:** As organizations grow, their network requirements change. Segmentation provides scalability and agility, allowing them to adapt to evolving needs without compromising security.

In network security, segmentation is not just a strategy; it's a necessity.

- If a non-segmented system is targeted by a rapidly spreading virus, it will not take long for the entire organization to be infected.
- However, if the same network had instead been segmented into six separate subnets, the virus could be contained to the single infected subnet, unable to spread to the rest of the system.

Access Control

- **Access control** refers to the process of allowing or restricting access of different parties to the organization's data, applications, network, or the cloud based on the organization's policies.
- There are two factors that are used to complete this task: the **Access Control List (ACL)** and **permissions**.
- **ACLs** are lists used by routers and firewall devices to grant or deny network traffic based on a set of rules.
- There are **two different kinds of ACLs, one for files and folders and another for incoming network traffic**.
- The first is implemented in a file and data access environment to control who gets access to the different types of data and also restrict what level of access they get. Access levels are then allotted according to the **principle of least privilege**, meaning that they are given only those permissions sufficient to meet the requirements of their respective job roles.

Access Control

- The **second kind of ACL** is implemented in a network environment. This list is placed on the firewall or router and its purpose is to decide when a user can access that network. A newly installed firewall or router will only contain one “deny all” rule, which means that all network traffic will be blocked by default, and to allow any access at all, you need to add exceptions to this rule. These exceptions are called allow rules.
- In addition to ACLs, effective access control also involves **permissions** to decide what access level users or systems are allowed to perform on a resource. These actions typically include read, write, execute, and delete, among others. Permissions are granted based on job roles and needs and are used to protect against unauthorized data tampering, deletions, and theft, preserving the security of sensitive information.

Application Allow List

- The application allow list specify a roster of approved applications that are permitted to execute while blocking unauthorized or potentially malicious software from gaining a foothold. This can be done by creating a **whitelist**, which is a list of approved applications that will deny access to any application not on the list.
- Let's say, for example, we have two problems with our network: a user called Bob who keeps installing games on his corporate computer, and a ransomware attack that installed malware and encrypted sensitive data. To prevent this from happening again, we need to create an **allow list** (also called a whitelist), which is a list of allowed applications.
- With an active allow list, your network knows to disallow all applications that are not explicitly permitted, meaning that any other applications or malware Bob or any other user attempts to install will be instantly blocked.

Application Block List

- An **application block list**, often referred to as a **deny list**, helps organizations enhance their network and data security by preventing specific applications from running.
- One tool for creating and managing such block lists is **Microsoft's AppLocker**. This software enables administrators to establish policies that restrict the execution of certain applications, adding an extra layer of protection against potential security threats.
- There are a few reasons for implementing an application block. Firstly, it helps mitigate security risks by explicitly preventing known vulnerable or malicious applications from running on systems. This reduces the chances of cyberattacks and malware infections.
- Application block lists can also be used to enforce compliance and productivity policies. For instance, you can use them to prevent unauthorized software installations or to restrict the usage of non-business-critical applications during work hours.
- Application block lists are created using an unapproved list, which is essentially a catalog of applications that you deem unsafe or unsuitable for your organization. The list contains the specific names or file paths of the applications that are prohibited. This creates a defense mechanism that automatically denies their execution, reducing the risk of accidental or intentional breaches caused by their usage.

Isolation

- Isolation is the practice of creating secure, self-contained environments within an enterprise's network.
- Its purpose is to confine critical systems or sensitive data.
- When isolating critical assets, organizations ensure that even if the outer defenses are breached, the critical assets are still protected.
- Isolation can also be used to control a malware attack by isolating any affected devices.

Patching

- The primary purpose of patching lies in fortifying systems and applications against security threats by applying regular updates and fixes, increasing their resilience to emerging vulnerabilities.
- By keeping software up to date, organizations minimize the risk of exploitation, ensuring that their digital assets remain secure and protected in the face of evolving cyber threats.
- Patching is not optional; it is mandatory so that systems can be protected against vulnerabilities.

Encryption

- The purpose of encryption is to transform sensitive data into an unreadable code to protect it from interception by malicious actors.
- Encryption ensures the confidentiality and integrity of data during transmission and storage.
- Whether it's safeguarding financial transactions, protecting personal messages, or securing sensitive corporate data, encryption is the invisible armor that ensures that information remains impervious to prying eyes.

Monitoring

- The purpose of monitoring is to keep a watchful eye on network and system activities and scan constantly for any anomalies or suspicious behavior.
- Monitoring ensures that any deviations from the norm are swiftly detected and addressed.
- Monitoring logs, traffic patterns, and system behavior not only aids in threat detection but also alerts the security operations center.
- This section will take a look at two real-time monitoring systems (SIEM and SOAR), defined as follows:

Two real-time monitoring systems (SIEM and SOAR), defined as follows:

- **Security Information and Event Management (SIEM):**
 - SIEM systems operate in real time, centralizing and correlating logs from servers and network devices and capturing network traffic.
 - Once these systems correlate the logs, they provide reports of threats to the security operations center, which can then take action to eradicate the attack.
- **Security Orchestration, Automation, and Response (SOAR):**
 - SOAR works in real time to tackle threats.
 - These systems use Artificial Intelligence (AI) and Machine Learning (ML) algorithms, with their capacity to decipher patterns, detect anomalies, and make data-driven decisions at lightning speed.
 - Playbooks are predefined sets of actions and workflows that guide the system's response to specific security incidents or events.
 - The SOAR system will release the IT staff for more important tasks as it searches the mundane logs faster than humans.